GRC

APPROVAL PACK · ICT RISK COMMITTEE

2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets

2LoD CISO Office (ICT risk control function)

REFERENCE	PERIOD	PLAN	OWNER	PACK AS OF
AP-2027-001	1 Jan 2027 – 31 Dec 2027	Approved, v1	PM (2LoD)	1 Dec 2026

CONFIDENTIAL

1 · DECISIONS REQUESTED

What we ask the ICT Risk Committee to decide

1

Approve the 2027 Security NFR controls testing plan: its scope (Tier 1 and Tier 2 ICT assets), objective and quarterly operating cycle.

2

Approve the sampling methodology: attribute sampling at the stated confidence and tolerable deviation rate per tier, the coverage floors, risk-based top-ups and the deviation rule.

3

Endorse the resourcing and the escalation triggers, and mandate asset owners to attest by each wave deadline.

Accountable: CISO (2LoD). Plan owner: PM (2LoD).

2 · REGULATORY BASIS

What the regulation asks, and how the plan meets it

Requirement	Reference	How the plan meets it
Assign the management and oversight of ICT risk to a control function with an appropriate level of independence, segregated from the first line and from internal audit.	DORA Art. 6(4)	The 2LoD CISO Office plans, tests and concludes; asset owners (1LoD) attest their own data; Internal Audit (3LoD) is informed and not part of the testing.
Identify, classify and document the ICT assets that support the business functions, and review the classification at least yearly.	DORA Art. 8(1)	Every Tier 1 and Tier 2 asset's Security NFR data is attested by its owner and data-quality reviewed by 2LoD within the year, in quarterly waves.
Identify all ICT assets, map those considered critical and their interdependencies, under an ICT asset management policy and procedure.	DORA Art. 8(4); RTS (EU) 2024/1774 Arts. 4–5	The scope population is extracted from the ICT asset inventory, reconciled to the critical or important function mapping, and frozen before the first draw.
Test the ICT systems and applications that support critical or important functions at least yearly.	DORA Art. 24(6)	Tier 1 assets support a critical or important function and are sample-tested against the Security NFRs every quarter. This complements the resilience testing programme; it does not replace it.
Review the ICT risk management framework at least yearly, and report on the review to the competent authority on request.	DORA Art. 6(5); RTS (EU) 2024/1774 Art. 27	The annual conclusion goes to the ICT Risk Committee and the management body as an input to the framework review report.

3 · OBJECTIVE

What the year delivers

> By 31 December 2027, 100% of Security NFR data for Tier 1 and Tier 2 ICT assets is reviewed and attested by 1LoD asset owners, with 2LoD performing a data-quality review of every submission and evidence-based sample testing of Security NFRs each quarter, giving an independent annual conclusion that feeds the ICT risk management framework review.

PLAN TYPE	PERIOD	MOBILISATION FROM	ANNUAL CONCLUSION
Controls testing plan (2LoD sample testing)	1 Jan 2027 – 31 Dec 2027	9 Nov 2026	28 Jan 2028

4 · SCOPE

What is in scope

POPULATION BY STRATUM

Stratum	Definition	Items
Tier 1	ICT assets supporting a critical or important function	80
Tier 2	Other business-critical ICT assets	240

Population frozen on 6 Nov 2026; seed commitment SHA-256 `4f35c493252c6cec…`

16 TEST ATTRIBUTES, TESTED ON EVERY SELECTED ITEM

NFR-01 Asset identification & classification
NFR-02 Security requirements specified & approved
NFR-03 Identity & authentication
NFR-04 Access management & recertification
NFR-05 Privileged access
NFR-06 Encryption at rest & key management
NFR-07 Encryption in transit
NFR-08 Logging & security monitoring
NFR-09 Vulnerability & patch management
NFR-10 Secure configuration & hardening
NFR-11 Network security & exposure
NFR-12 Security testing ≤ 12 months
NFR-13 Backup, recovery & RTO/RPO
NFR-14 Change management
NFR-15 Third-party, legacy & end-of-support
NFR-16 Exceptions & risk acceptance

5 · APPROACH

Two tracks: every item reviewed, a sample tested on evidence

Track 1 — 100% coverage review

- 1LoD owners review and attest every item in scope, in quarterly waves.
- 2LoD reviews the data quality of every submission and accepts it or returns it.
- Coverage is measured against a cumulative target per stratum at each quarter end, rated Green, Amber (within 10 points) or Red.
- Tier 1: waves 35% / 35% / 30% / 0%.
- Tier 2: waves 15% / 30% / 30% / 25%.

Track 2 — evidence-based sample testing

- Each quarter 2LoD draws a sample from the frozen population and tests every attribute on evidence.
- Samples are sized by attribute sampling at each stratum’s confidence and tolerable deviation rate, with a coverage floor and risk-based top-ups.
- The draw is ranked by a seed committed when the population is frozen, so any selection can be re-performed.
- Every test is QA-reviewed before its result counts; fails are raised as findings in Audit Findings.

6 · SAMPLING

Sample sizes and the deviation rule

Stratum	N	Confidence	Tolerable rate	n_0	With FPC	Floor	Annual sample	Planned tests	Coverage
Tier 1	80	95%	5%	59	35	20 (25%)	35	39	48.8%
Tier 2	240	90%	10%	22	21	12 (5%)	21	25	10.4%

The annual sample is the larger of the statistical size after the finite population correction and the coverage floor. Planned tests add the risk-based top-ups.

No deviations
Effective for the attribute in that stratum.

1 deviation
The sample is extended by 50% in the next quarter.

2 or more
Not effective: a thematic finding, raised to the risk register.

Counted per attribute and stratum, cumulatively over the year. A single test is Partially effective from 1 fail and Ineffective from 3.

7 · ROADMAP

The year at a glance

Mobilise
9 Nov – 31 Dec 2026

- Plan approved by the ICT Risk Committee (16 Dec 2026)
- Freeze the population; record the seed (18 Dec 2026)

Q1
1 Jan – 31 Mar 2027

- 1LoD wave: 64 item(s) attested by 26 Feb 2027
- 2LoD: 19 test(s), drawn 1 Mar 2027
- Report 30 Apr 2027; committee May 2027 (date TBC)

Q2
1 Apr – 30 Jun 2027

- 1LoD wave: 100 item(s) attested by 28 May 2027
- 2LoD: 20 test(s), drawn 31 May 2027
- Report 30 Jul 2027; committee Sep 2027 (date TBC)

Q3
1 Jul – 30 Sep 2027

- 1LoD wave: 96 item(s) attested by 27 Aug 2027
- 2LoD: 18 test(s), drawn 30 Aug 2027
- Tier 1 100% reviewed
- Report 29 Oct 2027; committee Nov 2027 (date TBC)

Q4
1 Oct – 31 Dec 2027

- 1LoD wave: 60 item(s) attested by 26 Nov 2027
- 2LoD: 7 test(s), drawn 29 Nov 2027
- 2028 plan approved
- Year-end: 100% of Tier 1 & 2 reviewed
- Report 28 Jan 2028; committee Feb 2028 (annual)

8 · QUARTERLY TARGETS

What each quarter must deliver

Target	Q1	Q2	Q3	Q4
Tier 1: attested by quarter end (cumulative)	35%	70%	100%	100%
Tier 1: items due in the wave	28	28	24	0
Tier 1: tests	14	13	11	1
Tier 2: attested by quarter end (cumulative)	15%	45%	75%	100%
Tier 2: items due in the wave	36	72	72	60
Tier 2: tests	5	7	7	6
All strata: tests	19	20	18	7
Report to the ICT Risk Committee	30 Apr 2027	30 Jul 2027	29 Oct 2027	28 Jan 2028

9 · OPERATING CYCLE

The same cycle every quarter

1	2	3	4	5	6	7
1LoD window opens	**1LoD deadline**	**Sample drawn**	**Fieldwork starts**	**Fieldwork ends**	**Findings agreed**	**Report**

	1LoD window opens	1LoD deadline	Sample drawn	Fieldwork starts	Fieldwork ends	Findings agreed	Report	Committee
Q1	11 Jan 2027	26 Feb 2027	1 Mar 2027	8 Mar 2027	9 Apr 2027	23 Apr 2027	30 Apr 2027	May 2027 (date TBC)
Q2	1 Apr 2027	28 May 2027	31 May 2027	7 Jun 2027	9 Jul 2027	23 Jul 2027	30 Jul 2027	Sep 2027 (date TBC)
Q3	1 Jul 2027	27 Aug 2027	30 Aug 2027	6 Sep 2027	8 Oct 2027	22 Oct 2027	29 Oct 2027	Nov 2027 (date TBC)
Q4	1 Oct 2027	26 Nov 2027	29 Nov 2027	1 Dec 2027	17 Dec 2027	14 Jan 2028	28 Jan 2028	Feb 2028 (annual)

Dates fall on business days. Evidence is due 10 business days after it is requested; later evidence is escalated.

10 · GOVERNANCE

Who sees progress, and what is escalated

REPORTING CADENCE

Forum	Frequency	Content
2LoD stand-up	Weekly	Progress against the quarter, blockers, RAID log
1LoD coordination	Fortnightly	Wave progress, overdue attestations, evidence requests
CISO status report	Monthly	KPI dashboard: coverage vs plan, tests, findings, utilisation
ICT Risk Committee	Quarterly	Quarterly progress report, deviations, plan changes for approval
Management body	Annual	Annual conclusion; input to the ICT risk management framework review

ESCALATION

Trigger	Escalate to	Within
Coverage more than 10 points behind plan	CISO and CIO	5 business days
Evidence more than 10 business days late	Owner's line manager, then CIO	5 business days, then 10
A Critical or High finding overdue, or an attribute concluded not effective	ICT Risk Committee	Next committee meeting
Utilisation above threshold	CISO (resource request)	Before the quarter's fieldwork starts

11 · RESOURCING

Resourcing and delivery risks

EFFORT AGAINST CAPACITY, PERSON-DAYS

	Testing	Reviews	Retests	Overhead	Capacity	Utilisation
Q1	52	12.4	0	10	100	74.4%
Q2	53	17.8	3	8	100	81.8%
Q3	47	16.8	5	8	100	76.8%
Q4	15	9	8	15	100	47%

The year needs 280 of 400 person-days (70%), from 2 tester FTE at 50 days a quarter. The threshold is 85%; the peak is Q2.

DELIVERY RISKS

No delivery risk flagged by the plan’s checks.

12 · NEXT STEPS

What happens next

Step	What	Responsible	When	Deliverable
0.4	Sampling methodology, sizes and deviation rule	2LoD Test Lead & testers	23 Nov 2026 – 4 Dec 2026	Sampling memo
0.6	Resourcing, tooling and evidence repository	PM (2LoD)	23 Nov 2026 – 11 Dec 2026	Resource plan; evidence repository ready
0.5	Agree 1LoD waves with asset owners	PM (2LoD)	30 Nov 2026 – 11 Dec 2026	Wave schedule agreed with asset owners
0.7	Coordinate with Internal Audit and Operational Risk	PM (2LoD)	30 Nov 2026 – 11 Dec 2026	Coordination note (reliance, overlap, timing)
0.8	Plan approved by the ICT Risk Committee	CISO (2LoD control function)	16 Dec 2026	Committee minute approving the plan
0.9	Freeze the population; record the seed	2LoD Test Lead & testers	18 Dec 2026	Frozen population and seed in the plan record

DECISIONS REQUESTED TODAY

1. Approve the 2027 Security NFR controls testing plan: its scope (Tier 1 and Tier 2 ICT assets), objective and quarterly operating cycle.
2. Approve the sampling methodology: attribute sampling at the stated confidence and tolerable deviation rate per tier, the coverage floors, risk-based top-ups and the deviation rule.
3. Endorse the resourcing and the escalation triggers, and mandate asset owners to attest by each wave deadline.